

Sesión 2

Análisis de integridad de datos

Entropía de Shannon, cifrado parcial, hashing difuso y scoring con IA — a escala

De mirar archivos uno por uno a puntuar el backup completo para hallar la copia limpia

Jawy Andrés Romero Pinto · Módulo 92-EAN · Universidad Ean · Educación Continua

2 horas · 1h teoría + 1h laboratorio

Agenda de la sesión

De la teoría de la información al scoring de un backup completo



De la Sesión 1 a la 2

Del análisis a mano al análisis a escala.



Entropía de Shannon

Qué es, cómo se calcula y qué significa 0 a 8 bits.



Cifrado parcial

Por qué la entropía global engaña; medir por bloques.



Magic number y hashing difuso

Extensión falsa y detección de variantes.



Scoring con IA

Detección de anomalías: ML + reglas + criterio humano.



Laboratorio (2ª hora)

features.csv y scoring del backup con scikit-learn.

La estrella polar (a escala)

La misma pregunta del curso, ahora sobre miles de archivos



«En un backup completo, ¿cuáles archivos están corruptos o cifrados y cuál copia está limpia para recuperar con confianza?»



Medir, no adivinar

La entropía cuantifica el desorden: base objetiva.



Ver lo que se esconde

El cifrado parcial exige mirar por bloques.



Priorizar a escala

El ML dice dónde mirar primero entre miles.



Criterio de investigador

El modelo prioriza; el analista decide.

De la Sesión 1 a la Sesión 2

El mismo criterio forense, ahora automatizado y a escala

Sesión 1 • a mano

- 8 archivos, uno por uno
- file, sha256sum, entropía a ojo
- Piensas como investigador
- Ideal para APRENDER las señales

Sesión 2 • a escala

- Miles de archivos automáticos
- Entropía por bloques + features
- Scoring con scikit-learn
- Ideal para PRIORIZAR y recuperar

El reto: un backup real es enorme

No puedes abrir cada archivo — necesitas medir

miles

de archivos en un solo respaldo
corporativo

0

tiempo para revisarlos uno por uno
en un incidente

1

objetivo: hallar la copia limpia para
recuperar

IA

prioriza dónde mirar; el analista
decide

La respuesta es una medida objetiva del 'desorden' de cada archivo: la entropía de Shannon.

Entropía de Shannon

La medida de incertidumbre / aleatoriedad de los datos

$$H = - \sum p_i \cdot \log_2 p_i$$

p_i = frecuencia de cada byte (0-255). Se mide en bits por byte, de 0 a 8.



BAJA (~0-3)

Datos muy predecibles/repetitivos
(texto plano, ceros).



MEDIA (~4-6)

Texto natural, CSV, config: algo de
estructura.



ALTA (~6-7)

Comprimidos o ejecutables: poca
redundancia.



MÁXIMA (~8)

Cifrado: bytes casi aleatorios — señal
de ransomware.

Entropía • ejemplo intuitivo

Mismo tamaño, muy distinta información

"AAAAAAAA"

$H = 0$ bits

Un solo símbolo: cero incertidumbre,
totalmente predecible.

texto natural

$H \approx 4-5$ bits

Varios símbolos con estructura del idioma.

datos cifrados

$H \approx 8$ bits

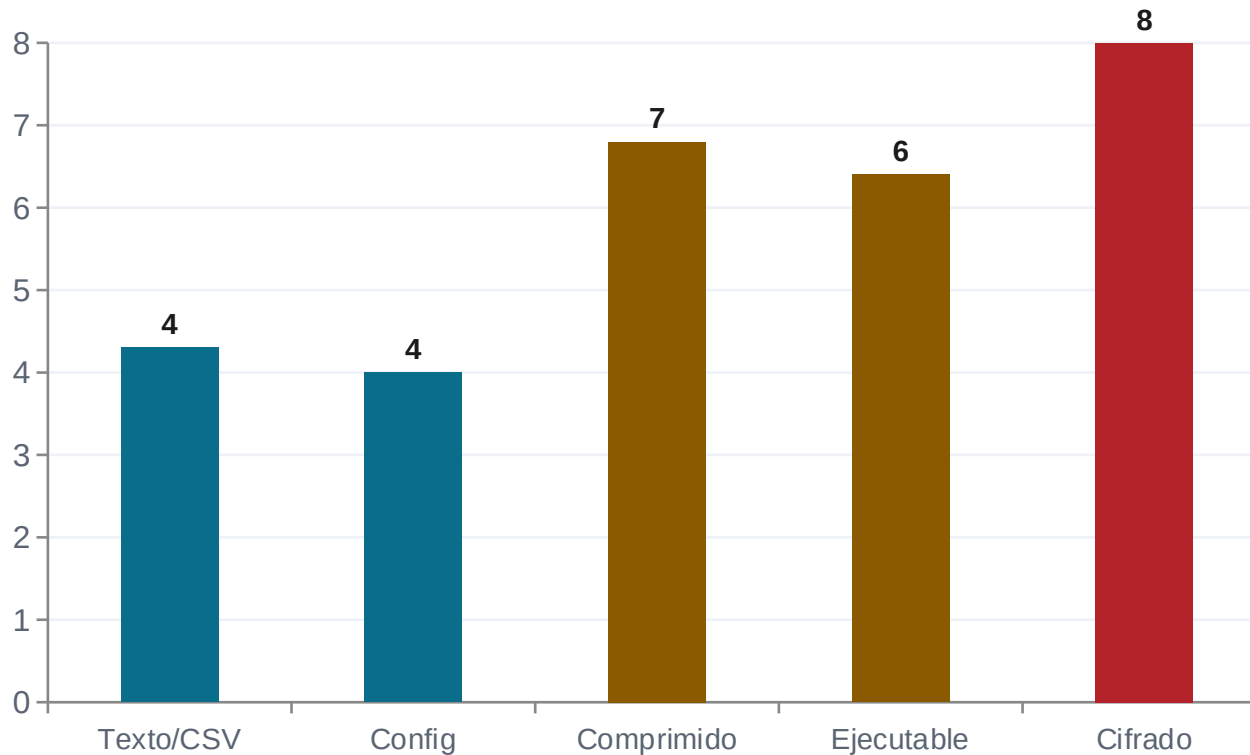
Todos los bytes por igual: máxima
incertidumbre.

Por eso un salto súbito a ~8 en un respaldo es una alarma: algo que debería ser texto ahora parece aleatorio.

Entropía típica por tipo de archivo

La frontera práctica para detectar cifrado

Entropía (bits/byte)



Regla práctica

Umbral ~7.5

Por encima de ~7.5 bits/byte el archivo es 'casi aleatorio': probable cifrado o compresión.

Ojo:

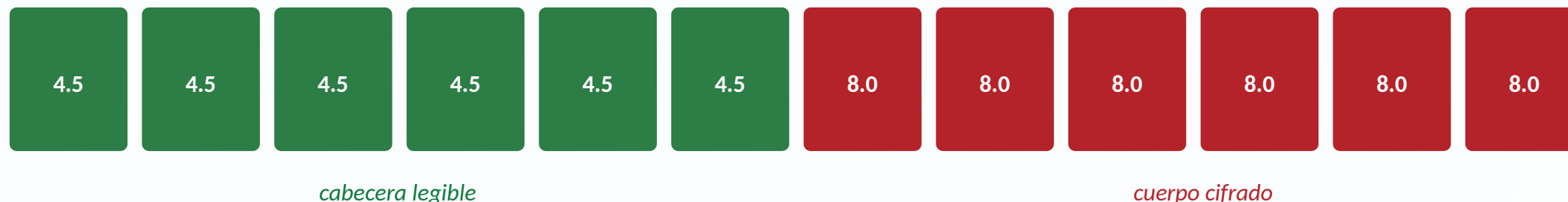
un comprimido legítimo también sube. Por eso combinamos entropía con magic y contexto.

La trampa: cifrado parcial

Cifrar solo una parte del archivo evade la entropía global

Algunos ransomware cifran solo un porcentaje del archivo (para ir más rápido). La entropía GLOBAL puede verse 'normal' — hay que medir POR BLOQUES.

Archivo dividido en bloques (entropía de cada uno):



La señal: la desviación estándar de la entropía entre bloques (`chunk_ent_std`) se dispara. Bloques bajos + bloques ~8 = cifrado parcial. En el lab lo detectamos automáticamente.

Magic number vs. extensión

El contenido no miente; la extensión sí

PNG

89 50 4E 47

primeros bytes

PDF

25 50 44 46

primeros bytes

ZIP/Office

50 4B 03 04

primeros bytes

JPG

FF D8 FF

primeros bytes

En la práctica: un archivo llamado factura.pdf cuyos primeros bytes son 89 50 4E 47 es en realidad un PNG. La herramienta file (o una tabla de firmas) lo delata. A escala, marcamos todos los que no coinciden.

¿Por qué importa para recuperar? Un archivo con extensión falsa puede ser malware disfrazado dentro del backup.

Hashing difuso (ssdeep / TLSH)

Detectar archivos parecidos, no solo idénticos

Un hash normal (SHA-256) cambia por completo con 1 byte. El hashing difuso mide SIMILITUD: agrupa variantes casi iguales y detecta la que rompe el grupo.



Caso de uso: entre muchas versiones de un documento, la variante troyanizada (con payload) se aleja del grupo. Útil también para reconocer familias de ransomware.

De señales a 'features'

Cada archivo se vuelve una fila de números medibles



entropy / por bloques

Cifrado total (global ~8) y parcial (std alto).



magic_mismatch

1 si el contenido no coincide con la extensión.



max_similarity

Cercanía a otros archivos (hashing difuso).



size / printable_ratio

Tamaño y proporción de bytes legibles.

Con estas columnas por archivo, un modelo puede aprender qué combinación es 'anómala' — sin abrir el archivo.

Detección de anomalías • IsolationForest

El modelo aísla lo 'raro' con pocas preguntas

La intuición

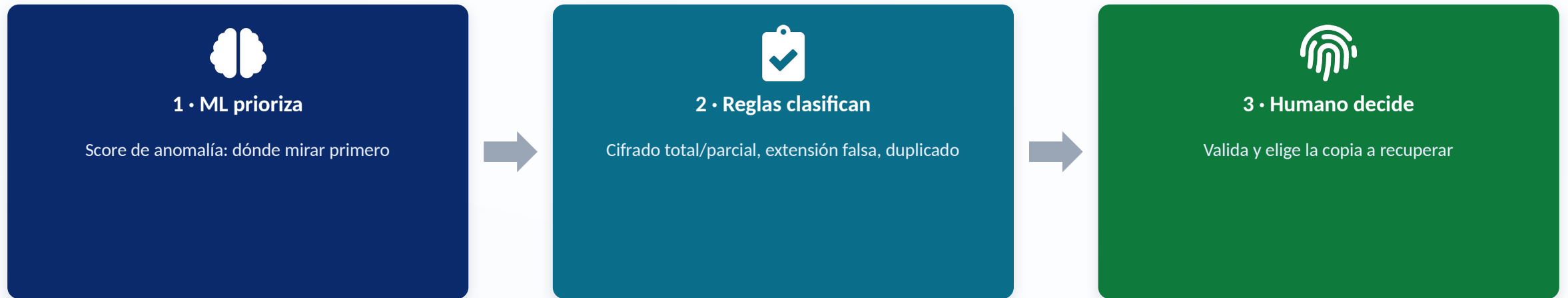
- Un punto NORMAL se parece a muchos: cuesta separarlo.
- Un punto RARO (anómalo) se aísla con pocos cortes.
- El modelo mide qué tan fácil es aislar cada archivo.
- Fácil de aislar = anómalo = score alto.

Para nuestro caso

- Entra: la tabla de features del backup.
- Sale: un score de corrupción 0–100 por archivo.
- No necesita ejemplos etiquetados (no supervisado).
- Nos dice DÓNDE mirar primero entre miles.

La regla de oro: tres capas

Ninguna basta sola — se complementan



Por qué importa: el ML puede dar falsos positivos (un archivo legítimo raro) y las reglas no cubren todo. Combinarlos, con criterio humano al final, es la ingeniería de detección real. Copiloto, no piloto.

El resultado: el backup, puntuado

De miles de archivos a una lista priorizada

ARCHIVO	SCORE	CLASIFICACIÓN
facturas/factura_v5_sospechosa.txt	100	cifrado_total
manual_parcial.pdf	91	cifrado_parcial
clientes_parcial.csv	85	cifrado_parcial
reporte_ventas.xlsx	74	extension_falsa
base_datos.sql.crypt	68	cifrado_total
clientes.csv	32	limpio

El analista revisa de arriba hacia abajo. Los 'limpio' con score bajo son candidatos a recuperación.

Por qué esto sirve a la recuperación

Integridad medible = recuperar con confianza



Hallar lo corrupto

Identificar rápido qué archivos no sirven.



Identificar la copia limpia

Elegir un punto de restauración verificado.



Priorizar lo crítico

Recuperar primero lo importante y sano.



Cerrar el ciclo

Insumo directo para la bóveda (S4) y el copiloto (S5).

Sin una medida objetiva de integridad, restaurar es una lotería. Con ella, la recuperación es una decisión informada.

Analogía • Fukushima Daiichi (2011)

Cuando todo lo digital falla, la copia en papel salva la operación

Tras el tsunami, la planta quedó en **apagón total (station blackout)**: sin energía, sin instrumentos y sin control digital.

Los operadores trabajaron con **linternas y baterías** conectadas a los medidores, y recurrieron a **manuales y planos en papel** para entender el estado de los reactores.

Con esa documentación operaron válvulas a mano y tendieron cables para **restablecer la energía** — todo bajo **radiación creciente**.



Trabajador midiendo radiación frente a un edificio de reactor dañado, Fukushima Daiichi.

La lección para tus backups

El papel fue su copia inmutable y fuera de línea



Manuales/planos en papel

→ Copia offline / inmutable — el '1' de 3-2-1-1-0

Fuera de línea: nada digital los borra

→ Air-gapped / WORM — el ransomware no los cifra

Permitieron restablecer energía y operar

→ Runbooks de recuperación impresos y a la mano

Documentación confiable y verificada

→ El '0': recuperación probada, sin sorpresas

Tu última línea de defensa no es la más avanzada: es la que el atacante no puede tocar.

Herramientas del mercado vs. nuestro lab

Replicamos la capacidad, no la marca — sin licencias

Capacidad	Producto comercial	Nuestro equivalente open source
Integridad de contenido	CyberSense (Dell PowerProtect)	entropía+magic+hashing+ML · S1-S2
Anomalías en snapshots	Rubrik / Cohesity	scoring con scikit-learn · S2
Detección de variantes	motores de firmas + ML	YARA/Sigma con LLM · S3
Bóveda inmutable	PowerProtect Cyber Recovery	MinIO Object Lock, restic, AIDE · S4
Integridad por hash / FIM	Tripwire · Veeam	sha256sum + AIDE/Wazuh · S1,S4

No competimos con CyberSense: entendemos y replicamos su capacidad para auditarla y no depender de licencias.

Backups en nube pública: qué es nativo

AWS y Azure — incluidas bases de datos (RDS / Azure SQL)

Capacidad	AWS (nativo)	Azure (nativo)
Backup + PITR	RDS/Aurora snapshots, PITR	Azure SQL PITR, LTR
Inmutabilidad (WORM)	Backup Vault Lock · S3 Object Lock	SQL immutability · immutable vault
Amenazas (actividad)	GuardDuty RDS Protection	Microsoft Defender for SQL
Malware en backups	GuardDuty Malware Protection	Defender for Cloud + Backup
Integridad de CONTENIDO (entropía)	✗ No nativo → tú/terceros	✗ No nativo → tú/terceros

La nube te da la bóveda y la alarma de la puerta; saber si el contenido del respaldo está sano lo pones tú.

Los riesgos de confiar solo en lo nativo

Lo que la nube pública no resuelve por sí sola



Hueco de integridad

La nube no te dice si el CONTENIDO del backup está cifrado/corrupto. Falta el análisis.



Responsabilidad compartida

El proveedor asegura la infra; la config del backup (retención, WORM, acceso) es tuya.



Malas configuraciones

Sin Object Lock, soft-delete ≠ inmutable, retención corta → el borrado/ransomware gana.



Identidad comprometida

Credenciales/IAM con permisos pueden borrar backups si no hay WORM ni MFA-delete.

Arquitectura correcta = inmutabilidad nativa + análisis de integridad (tú/terceros) + detección de amenazas.

IA responsable (recordatorio)

El modelo va a la data, no la data al modelo



Local por defecto

El scoring y el copiloto corren en tu entorno.



Evidencia no se expone

Datos reales/PII nunca a un modelo público.



En clase: dato sintético

El backup del lab es sintético; hosted es aceptable.



Humano en el lazo

El score prioriza; el analista valida y decide.

Mismo principio de la Sesión 1: la elección del modelo es una decisión forense (OWASP LLM01).

El taller de hoy • dos tiempos

Primero medir a escala, luego puntuar con IA

Parte 1 • Análisis a escala

- Generar el backup del caso (a escala)
- Ver el cifrado parcial a mano (head/tail)
- `extraer_features.py` → `features.csv`
- Leer entropía por bloques, magic, similitud



Parte 2 • Scoring + IA

- `score.py` → IsolationForest + reglas
- Lista priorizada (score + clasificación)
- Copiloto local resume y recomienda
- Contrastar: ¿coincide?, ¿falsos positivos?

Próxima sesión • qué viene y qué alistar

Sesión 3 — Detección de variantes asistida por IA

En la Sesión 3 veremos

- Reglas YARA y Sigma para detección
- Generarlas con un LLM local desde informes CTI
- Validarlas con yara / sigma-cli
- Del reporte de amenaza a la regla funcional
- Detectar familias/variantes de ransomware

Qué debes traer listo

- El lab de hoy funcionando (features + score)
- Entorno del kit con scikit-learn (make check)
- El repo actualizado (git pull)
- Modelo local operativo o API configurada
- Dudas de esta sesión resueltas

¿Preguntas antes del laboratorio?



Idea para llevarse: la integridad se MIDE. Entropía, magic y similitud convierten un backup gigante en una lista priorizada para recuperar con confianza.